

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



**TIỂU LUẬN KẾT THÚC HỌC PHẦN
BẢO MẬT IoT**

QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT QUY MÔ NHỎ

Giảng viên hướng dẫn: Hồ Nhật Minh

Lớp học phần: 253INT441001

Mã học phần : INT4410

Sinh viên thực hiện: Võ Nguyễn Duyên

Mã số sinh viên: 231A010722

TP. HỒ CHÍ MINH

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



TIỂU LUẬN KẾT THÚC HỌC PHẦN

BẢO MẬT IoT

QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT QUY MÔ NHỎ

Giảng viên hướng dẫn: Hồ Nhật Minh

Lớp học phần: 253INT441001

Mã học phần : INT4410

Sinh viên thực hiện: Võ Nguyễn Duyên

Mã số sinh viên: 231A010722

TP. HỒ CHÍ MINH

LỜI CAM KẾT

Về việc sử dụng Trí tuệ nhân tạo (AI) trong quá trình nghiên cứu:

Em xin minh bạch tuyên bố rằng, trong quá trình thực hiện bài tiểu luận này, em có sử dụng các công cụ AI Claude và ChatGPT để hỗ trợ cho các công việc: hiệu đính ngữ pháp, chính tả; hỗ trợ dịch thuật một số tài liệu tham khảo nước ngoài; gợi ý, hoàn thiện cấu trúc dàn ý của bài viết; và tạo một số hình ảnh minh họa, sơ đồ kiến trúc/quy trình (nhóm tác giả tự hiệu chỉnh lại nhãn, chú thích và bố cục cho phù hợp với đề tài). Các công cụ này chỉ đóng vai trò hỗ trợ về mặt trình bày và diễn đạt; toàn bộ ý tưởng cốt lõi, phương pháp phân tích rủi ro bảo mật, nội dung nghiên cứu và kết luận của bài tiểu luận đều do em tự tìm hiểu, thực hiện dưới sự hướng dẫn của giảng viên. Em xin hoàn toàn chịu trách nhiệm về tính trung thực, tính nguyên bản và tính chính xác học thuật của toàn bộ nội dung bài làm.

TP.Hồ Chí Minh, ngày 31 tháng 07 năm 2026

Sinh viên thực hiện



Võ Nguyễn Duyên

NHẬN XÉT CỦA GIẢNG VIÊN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

TP.Hồ Chí Minh, ngày 31 tháng 07 năm 2026

Giảng viên bộ môn

MỤC LỤC

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Phát biểu vấn đề bảo mật	1
1.3. Mục tiêu của đề tài	1
1.4. Đối tượng, phạm vi và giới hạn an toàn	2
1.5. Sản phẩm và kết quả dự kiến	2
1.6. Cấu trúc báo cáo	2
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	4
2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống	4
2.2. Khái niệm bảo mật trực tiếp liên quan	4
2.3. Trọng tâm theo hướng	6
2.4. Chuẩn, công cụ và nguồn GitHub chính	7
2.5. Công trình hoặc giải pháp liên quan	7
2.6. Tiểu kết Chương 2	8
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	9
3.1. Phương pháp thực hiện	9
3.2. Mô hình/kiến trúc đề xuất	9
3.3. Môi trường, công cụ và dữ liệu	10
3.4. Quy trình triển khai/đánh giá	11
3.5. Tiêu chí đánh giá	11
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ	13
4.1. Chuẩn bị môi trường	13
4.2. Thành phần sản phẩm	13
4.3. Kịch bản thử nghiệm/áp dụng	14
4.4. Kết quả	14
4.5. Script sinh báo cáo	15
4.6. Thảo luận và hạn chế	16
4.6.1. Đối chiếu kết quả với mục tiêu	16
4.6.2. Hạn chế	16
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	17
5.1. Tài sản và dữ liệu	17

5.2. Mối đe dọa và lỗ hổng.....	17
5.3. Ma trận rủi ro	18
5.4. Biện pháp giảm thiểu	19
5.5. Rủi ro còn lại.....	20
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	21
6.1. Kết luận	21
6.2. Hạn chế	21
6.3. Hướng phát triển	21
TÀI LIỆU THAM KHẢO	22
PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP	23
PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP	24
PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP	24
PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC.....	25

DANH MỤC BẢNG

Bảng 5.1. Tài sản và dữ liệu cần bảo vệ	17
Bảng 5.2. Môi đe dọa và lỗ hổng	18
Bảng 5.3. Ma trận rủi ro	19
Bảng 5.4. Checklist kiểm tra bảo mật định kỳ	20

DANH MỤC HÌNH ẢNH

Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ	4
Hình 2.2. Quy trình quản lý rủi ro.....	6
Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ.....	10
Hình 3.2. Quy trình triển khai đánh giá rủi ro.....	11
Hình 4.1. Kết quả lập danh mục tài sản của hệ thống IoT	14
Hình 4.2. Kết quả xây dựng Risk Register	15
Hình 4.3. Ma trận đánh giá rủi ro 5×5	15

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Nghĩa đầy đủ / Giải thích
CIA	Confidentiality, Integrity, Availability – Tính bí mật, tính toàn vẹn, tính sẵn sàng
CSF	Cybersecurity Framework – Khung an toàn thông tin (NIST)
HTTP/HTTPS	HyperText Transfer Protocol (Secure) – Giao thức truyền tải siêu văn bản (có bảo mật)
IDS/IPS	Intrusion Detection/Prevention System – Hệ thống phát hiện/ngăn chặn xâm nhập
IoT	Internet of Things – Internet vạn vật
ISTG	IoT Security Testing Guide – Hướng dẫn kiểm thử bảo mật IoT (OWASP)
ISVS	IoT Security Verification Standard – Chuẩn xác minh bảo mật IoT (OWASP)
MQTT	Message Queuing Telemetry Transport – Giao thức truyền dữ liệu IoT dạng publish/subscribe
NIST	National Institute of Standards and Technology – Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ
OWASP	Open Web Application Security Project – Dự án an toàn ứng dụng web mở
SIEM	Security Information and Event Management – Hệ thống quản lý thông tin và sự kiện an toàn
SP 800-30	Special Publication 800-30 – Tài liệu hướng dẫn đánh giá rủi ro của NIST

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Internet of Things (IoT) đang phát triển mạnh mẽ và được ứng dụng rộng rãi trong nhiều lĩnh vực như nhà thông minh, nông nghiệp, y tế, giáo dục và doanh nghiệp. Các thiết bị IoT có khả năng thu thập, truyền tải và xử lý dữ liệu theo thời gian thực, góp phần nâng cao hiệu quả quản lý và tối ưu chi phí vận hành.

Tuy nhiên, các hệ thống IoT quy mô nhỏ vẫn tiềm ẩn nhiều nguy cơ mất an toàn thông tin do hạn chế về chi phí và khả năng quản trị. Nhiều thiết bị còn sử dụng mật khẩu mặc định, chưa cập nhật firmware thường xuyên, thiếu cơ chế xác thực và mã hóa dữ liệu, làm tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và bị tấn công mạng.

Theo OWASP Internet of Things Security Project (2024), các lỗ hổng phổ biến của IoT gồm mật khẩu mặc định, cấu hình không an toàn và thiếu cơ chế cập nhật firmware. NIST SP 800-30 Revision 1 (2012) cũng khuyến nghị đánh giá rủi ro thông qua việc nhận diện tài sản, xác định mối đe dọa, đánh giá tác động và đề xuất biện pháp giảm thiểu.

Xuất phát từ thực tế trên, đề tài “Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ” được thực hiện nhằm nhận diện tài sản, phân tích mối đe dọa và lỗ hổng bảo mật, đánh giá mức độ rủi ro, từ đó đề xuất các biện pháp giảm thiểu phù hợp với điều kiện triển khai thực tế.

1.2. Phát biểu vấn đề bảo mật

Hệ thống IoT quy mô nhỏ gồm nhiều tài sản quan trọng như thiết bị IoT, dữ liệu cảm biến, firmware, tài khoản quản trị và hạ tầng mạng. Do hạn chế về chi phí và khả năng quản trị, các hệ thống này thường tồn tại nhiều lỗ hổng như mật khẩu yếu, firmware chưa cập nhật, thiếu cơ chế mã hóa và xác thực, làm gia tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và tấn công mạng.

Nếu không được đánh giá và kiểm soát kịp thời, các rủi ro này sẽ ảnh hưởng đến tính bí mật, tính toàn vẹn và tính sẵn sàng của hệ thống. Vì vậy, đề tài tập trung xây dựng mô hình quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ thông qua việc nhận diện tài sản, xác định mối đe dọa, xây dựng Risk Register, đánh giá rủi ro bằng ma trận 5×5 và đề xuất các biện pháp giảm thiểu phù hợp.

1.3. Mục tiêu của đề tài

Đề tài được thực hiện nhằm đạt được các mục tiêu sau:

- MT-01: Xác định và phân loại các tài sản quan trọng trong hệ thống IoT quy mô nhỏ.
- MT-02: Phân tích các mối đe dọa, lỗ hổng và đánh giá mức độ rủi ro đối với từng tài sản.
- MT-03: Xây dựng Risk Register và ma trận đánh giá rủi ro 5×5 .
- MT-04: Đề xuất các biện pháp xử lý và giảm thiểu rủi ro có mức độ cao.
- MT-05: Xây dựng checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu: Hệ thống IoT quy mô nhỏ gồm thiết bị IoT, gateway, dữ liệu cảm biến, tài khoản quản trị và hạ tầng mạng.

Phạm vi nghiên cứu: Đề tài đánh giá rủi ro trên mô hình IoT giả lập, tham khảo các tiêu chuẩn OWASP IoT Security Project và NIST SP 800-30 để đề xuất giải pháp bảo mật.

Giới hạn nghiên cứu: Đề tài không thực hiện tấn công trên thiết bị IoT thực tế, không thu thập dữ liệu cá nhân và chỉ tập trung vào việc nhận diện, đánh giá và quản lý rủi ro bảo mật.

1.5. Sản phẩm và kết quả dự kiến

Sau khi hoàn thành, đề tài dự kiến đạt được các sản phẩm sau:

Sơ đồ kiến trúc tổng thể của hệ thống IoT quy mô nhỏ.

Danh sách các tài sản cần bảo vệ trong hệ thống.

Risk Register gồm tối thiểu 6 rủi ro bảo mật.

Ma trận đánh giá rủi ro 5×5.

Kế hoạch xử lý và giảm thiểu đối với toàn bộ 6 rủi ro theo mức độ ưu tiên.

Checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.

README mô tả phạm vi nghiên cứu, nguồn tài liệu tham khảo và hướng dẫn sử dụng các sản phẩm của đề tài.

1.6. Cấu trúc báo cáo

Phần còn lại của báo cáo được tổ chức như sau: Chương 2 trình bày cơ sở lý thuyết, kiến trúc hệ thống và các nguồn tài liệu liên quan; Chương 3 mô tả phương pháp và thiết kế nghiên cứu; Chương 4 trình bày quá trình triển khai, sản phẩm và kết quả đạt được; Chương 5 trình bày chi tiết kết quả đánh giá bảo mật gồm tài sản, mối đe dọa, ma trận rủi ro và biện pháp giảm thiểu; Chương 6 tổng kết các kết quả đạt được và đề xuất hướng phát triển.

Repo GitHub cá nhân của đề tài: <https://github.com/vonguyenduyen512-oss/231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot> (toàn bộ báo cáo, sơ đồ, Risk Register, ma trận rủi ro và checklist được lưu trong repo này).

Bảng đối chiếu mục tiêu và đầu ra

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01	Danh mục 6 tài sản, phân theo chủ thể và mức độ quan trọng	Đối chiếu Bảng 5.1	Chương 5, mục 5.1
MT-02	6 cặp mối đe dọa – lỗ hổng được phân tích	Đối chiếu Bảng 5.2	Chương 5, mục 5.2

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-03	Risk Register và ma trận đánh giá rủi ro 5×5	Đối chiếu Bảng 5.2, 5.3	Chương 5, mục 5.2–5.3
MT-04	Kế hoạch xử lý cho toàn bộ 6 rủi ro theo ưu tiên	Đối chiếu Bảng 5.3	Chương 5, mục 5.4
MT-05	Checklist kiểm tra bảo mật định kỳ, 6 hạng mục theo tuần/tháng/quý	Đối chiếu Bảng 5.4	Chương 5, mục 5.4

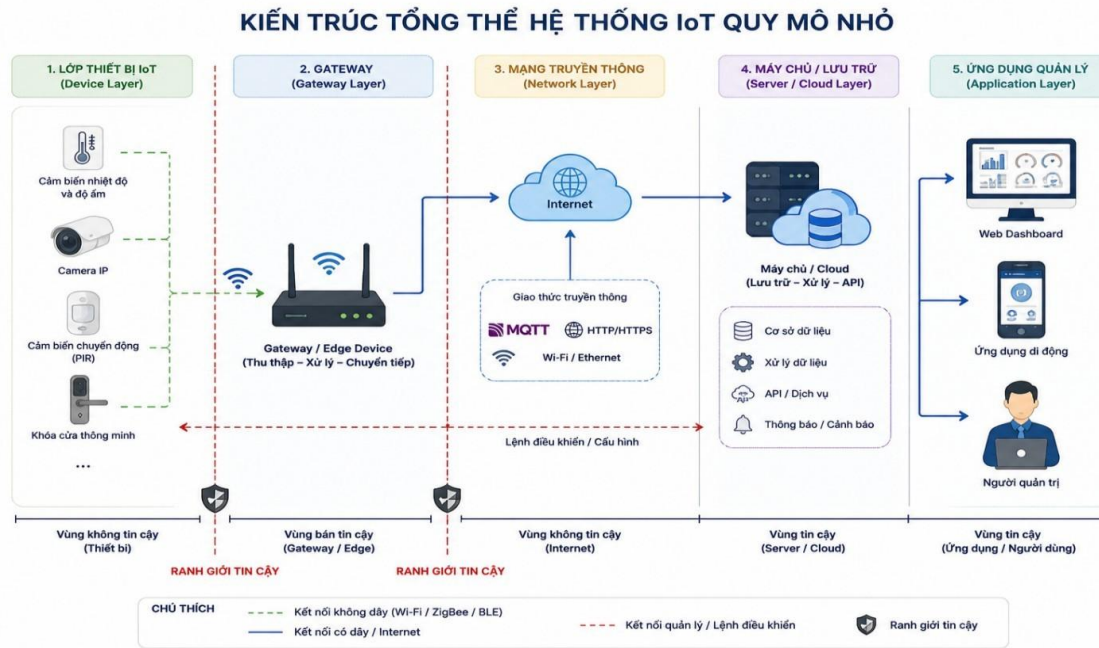
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống

Hệ thống IoT quy mô nhỏ trong phạm vi đề tài được xây dựng theo mô hình gồm 5 thành phần chính: lớp thiết bị IoT, gateway, mạng truyền thông, máy chủ/lưu trữ và ứng dụng quản lý (Hình 2.1). Đây là mô hình phổ biến trong các hộ gia đình, phòng thí nghiệm và doanh nghiệp nhỏ, cho phép thu thập, truyền tải và quản lý dữ liệu từ các thiết bị IoT.

Ở lớp thiết bị, các cảm biến, camera IP và khóa thông minh thực hiện thu thập dữ liệu hoặc điều khiển thiết bị. Dữ liệu được gateway tiếp nhận, xử lý sơ bộ và truyền qua mạng bằng các giao thức như MQTT hoặc HTTP/HTTPS đến máy chủ để lưu trữ, xử lý và cung cấp dịch vụ. Người quản trị có thể giám sát và điều khiển hệ thống thông qua giao diện web hoặc ứng dụng di động.

Trong kiến trúc này, dữ liệu truyền giữa các thành phần cần được bảo vệ bằng các cơ chế xác thực, mã hóa và kiểm soát truy cập nhằm hạn chế nguy cơ truy cập trái phép, nghe lén hoặc giả mạo dữ liệu. Các ranh giới tin cậy trong hệ thống cũng là cơ sở để xác định tài sản và đánh giá rủi ro.



Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh nhân, chú thích tiếng Việt và bố cục các lớp kiến trúc cho phù hợp với đề tài (2026).

2.2. Khái niệm bảo mật trực tiếp liên quan

Tài sản (Asset): Tài sản là những thành phần có giá trị cần được bảo vệ trong hệ thống. Đối với hệ thống IoT, tài sản bao gồm thiết bị IoT, gateway, dữ liệu cảm biến, tài khoản quản trị, firmware, khóa mã hóa và hạ tầng mạng.

Lỗ hổng (Vulnerability): Lỗ hổng là điểm yếu tồn tại trong thiết bị, phần mềm hoặc quy trình quản lý có thể bị kẻ tấn công khai thác. Ví dụ như sử dụng mật khẩu mặc định, firmware chưa cập nhật, cấu hình sai hoặc giao tiếp không được mã hóa.

Rủi ro (Risk): Rủi ro là khả năng xảy ra sự cố bảo mật khi một mối đe dọa khai thác thành công lỗ hổng của hệ thống và gây ra thiệt hại đối với tài sản. Trong đề tài, mức độ rủi ro được đánh giá theo công thức: $Risk = Likelihood \times Impact$, trong đó Likelihood là khả năng xảy ra và Impact là mức độ ảnh hưởng của sự cố.

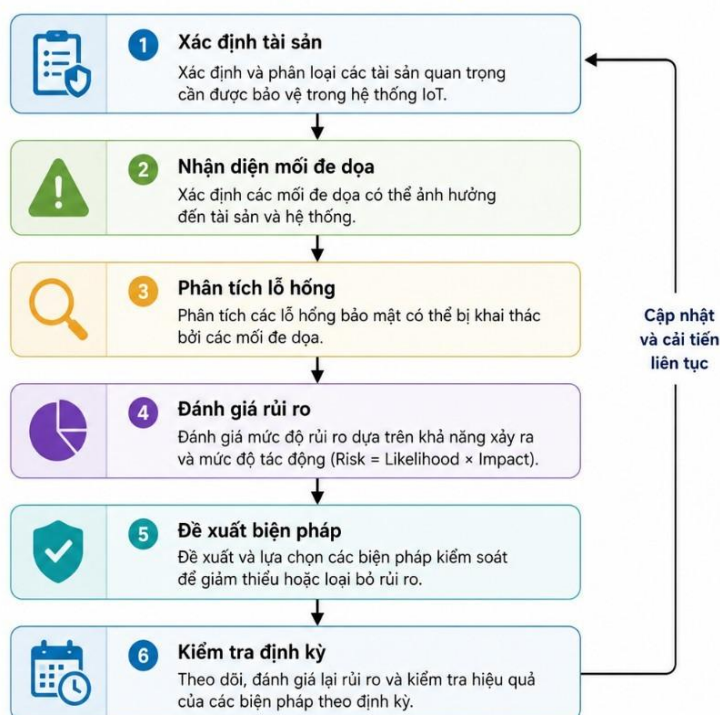
Mô hình CIA gồm ba thuộc tính cơ bản: Confidentiality (tính bí mật) đảm bảo dữ liệu chỉ được truy cập bởi các đối tượng được phép; Integrity (tính toàn vẹn) đảm bảo dữ liệu không bị thay đổi trái phép trong quá trình lưu trữ hoặc truyền tải; Availability (tính sẵn sàng) đảm bảo hệ thống luôn sẵn sàng phục vụ người dùng khi cần thiết.

Xác thực và phân quyền: Xác thực (Authentication) là quá trình kiểm tra danh tính của người dùng hoặc thiết bị trước khi cho phép truy cập hệ thống. Sau khi xác thực thành công, cơ chế phân quyền (Authorization) sẽ quyết định các chức năng mà người dùng được phép thực hiện.

Firmware: Firmware là chương trình điều khiển được cài đặt trực tiếp trên thiết bị IoT. Nếu firmware tồn tại lỗ hổng hoặc không được cập nhật định kỳ, thiết bị dễ bị khai thác; do đó firmware cần được cập nhật thường xuyên để khắc phục lỗ hổng bảo mật.

Đề tài thuộc Hướng G – Quản trị rủi ro, chính sách, checklist và kiểm thử, vì vậy nội dung được vận dụng theo một quy trình quản lý rủi ro gồm các bước: xác định tài sản, nhận diện mối đe dọa và lỗ hổng, đánh giá mức độ rủi ro, đề xuất biện pháp giảm thiểu và kiểm tra định kỳ (Hình 2.2). Quy trình này là khung tham chiếu xuyên suốt cho Chương 3 và Chương 5 của báo cáo.

Hình 2.2. Quy trình quản lý rủi ro



Hình 2.2. Quy trình quản lý rủi ro. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh các bước và nhãn quy trình theo khung NIST SP 800-30 áp dụng trong đề tài (2026).

2.3. Trọng tâm theo hướng

Hướng	Mã đề tài	Chương 2 phải tập trung	Hình/bảng nên có
☐ A	01-10	Kiến trúc IoT, bối cảnh ứng dụng, tài sản/dữ liệu và chuẩn đánh giá.	Sơ đồ hệ thống; bảng tài sản-nguy cơ.
☐ B	11-19, 49	Đặc tính giao thức/mạng/API, cơ chế xác thực-mã hóa và cấu hình an toàn.	Bảng so sánh; sơ đồ luồng; cấu hình mẫu.
☐ C	20, 30, 31, 42, 45	Firmware, boot/update, phần cứng, lưu trữ khóa và bề mặt thiết bị.	Chuỗi boot/update; bảng điểm kiểm tra.
☐ D	21-29, 32	Mô hình tấn công, điều kiện xảy ra, tác động, quyền riêng tư và phòng thủ nhiều lớp.	Attack tree/DFD; bảng STRIDE/rủi ro.
☐ E	33-34	Lưu lượng IoT, bất thường, IDS, đặc trưng/rule và chỉ số đánh giá.	Luồng phát hiện; bảng đặc trưng/chỉ số.
☐ F	36-41, 43-44	Thuật toán, khóa/chứng chỉ, xác thực, toàn vẹn và chi phí tài nguyên IoT.	Sơ đồ vòng đời khóa; bảng so sánh.
☒ G	35, 46-48, 50	Quản trị rủi ro, chuẩn OWASP/ISVS/ISTG, policy, checklist và quy trình kiểm thử.	Khung tiêu chí; quy trình; ma trận vai trò.

Vì thuộc hướng G, Chương 2 của đề tài tập trung vào ba nội dung: khung tiêu chí đánh giá, quy trình quản trị rủi ro và ma trận vai trò/trách nhiệm.

Khung tiêu chí: đề tài áp dụng bốn nhóm tiêu chí bảo mật của OWASP ISVS làm khung đánh giá xuyên suốt – (i) Communication security (xác thực, mã hóa kênh truyền), (ii) Software security (cập nhật firmware, quản lý phiên bản), (iii) Hardware security (bảo vệ vật lý thiết bị), (iv) Data protection (mã hóa và kiểm soát truy cập dữ liệu). Mỗi tài sản trong Risk Register (Bảng 5.2) được ánh xạ vào một hoặc nhiều nhóm tiêu chí này khi xác định mối đe dọa – lỗ hổng.

Quy trình: quy trình quản trị rủi ro gồm 5 bước minh họa tại Hình 2.2 (xác định tài sản → nhận diện mối đe dọa/lỗ hổng → đánh giá rủi ro theo ma trận 5×5 → đề xuất biện pháp giảm thiểu → kiểm tra định kỳ bằng checklist), được lặp lại theo chu kỳ tuần/tháng/quý như trình bày tại Bảng 5.4.

Ma trận vai trò: ba vai trò chính tham gia quy trình – Người quản trị hệ thống (cập nhật firmware, cấu hình thiết bị), Quản trị viên bảo mật/tác giả đề tài (xây dựng Risk Register, ma trận rủi ro, đề xuất biện pháp), và Người dùng cuối (tuân thủ checklist định kỳ, báo cáo bất thường). Việc phân vai này được thể hiện qua cột "Chủ thể" tại Bảng 5.1 và áp dụng nhất quán trong toàn bộ Chương 5.

2.4. Chuẩn, công cụ và nguồn GitHub chính

STT	Nguồn/repo	URL/phần bản	Phần đã sử dụng	Truy cập
1	OWASP IoT Security Verification Standard (ISVS)	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Khung yêu cầu bảo mật (Communication, Software, Hardware, Data Protection) dùng để xây dựng Risk Register và checklist kiểm tra định kỳ.	04/07/2026
2	OWASP IoT Security Testing Guide (ISTG)	https://github.com/OWASP/owasp-istg	Tham khảo phương pháp và quy trình kiểm thử các hạng mục trong checklist bảo mật.	04/07/2026
3	OWASP Internet of Things Project	https://github.com/OWASP/www-project-internet-of-things	Tham khảo OWASP IoT Top 10 để xác định mối đe dọa và lỗ hổng phổ biến.	04/07/2026
4	Practical IoT Security (B. Russell, D. Van Duren, Packt, 2016)	Sách	Tham khảo mô hình tài sản – mối đe dọa – lỗ hổng trong quản lý rủi ro IoT.	04/07/2026
5	IoT Security Guidelines Ver. 1.0	Tài liệu	Tham khảo các nguyên tắc và hướng dẫn triển khai bảo mật IoT tổng quát.	04/07/2026
6	Node-RED	https://github.com/node-red/node-red	Tham khảo mô hình gateway và luồng dữ liệu trong kiến trúc IoT (không sử dụng mã nguồn).	04/07/2026

2.5. Công trình hoặc giải pháp liên quan

Đề tài tham khảo và kế thừa ba nhóm giải pháp/nguồn gần nhất sau đây:

(1) NIST SP 800-30 Rev.1 – mục tiêu là cung cấp quy trình đánh giá rủi ro tổng quát cho mọi loại hệ thống CNTT; cách làm dựa trên định tính/định lượng kết hợp, quy mô lớn, đòi hỏi nhiều tài liệu và vai trò tổ chức chuyên trách; ưu điểm là toàn diện, được công nhận rộng rãi, nhưng nhược điểm là cồng kềnh với hệ thống IoT quy mô nhỏ, không có hướng dẫn kỹ thuật riêng cho IoT. Đề tài kế thừa công thức $Risk = Likelihood \times Impact$ và quy trình 5 bước, nhưng rút gọn tài liệu và biểu mẫu cho phù hợp quy mô nhỏ.

(2) OWASP IoT Security Verification Standard (ISVS) – mục tiêu là đưa ra danh mục yêu cầu bảo mật kỹ thuật (xác thực, mã hóa, phần cứng, dữ liệu) để xác minh sản phẩm IoT; cách làm theo dạng checklist yêu cầu theo cấp độ; ưu điểm là cụ thể, dễ áp dụng cho kiểm thử; nhược điểm là không

có phần đánh giá rủi ro theo ma trận khả năng $\times$ tác động. Đề tài kế thừa danh mục yêu cầu của ISVS để xây dựng checklist kiểm tra định kỳ (Bảng 5.4), đồng thời bổ sung phần ma trận rủi ro mà ISVS không có.

(3) Practical IoT Security (Russell & Van Duren, 2016) – mục tiêu là trình bày các thành phần rủi ro (tài sản – mối đe dọa – lỗ hổng) qua ví dụ thực tế trong công nghiệp; cách làm mang tính minh họa case-study hơn là quy trình chuẩn hóa; ưu điểm là dễ hiểu, sát thực tiễn thiết bị; nhược điểm là thiếu công cụ định lượng mức độ ưu tiên xử lý rủi ro. Đề tài kế thừa cách phân loại tài sản – mối đe dọa – lỗ hổng của tài liệu này khi xây dựng Risk Register (Bảng 5.2), kết hợp với ma trận 5×5 định lượng của NIST để khắc phục nhược điểm nêu trên.

Tổng hợp lại, đề tài kế thừa quy trình đánh giá rủi ro của NIST, danh mục yêu cầu kỹ thuật của OWASP ISVS và cách phân loại thành phần rủi ro của Russell & Van Duren, đồng thời tinh gọn và kết hợp ba nguồn này thành một mô hình quản lý rủi ro phù hợp với hệ thống IoT quy mô nhỏ.

2.6. Tiểu kết Chương 2

Chương 2 đã trình bày kiến trúc tổng quan của hệ thống IoT quy mô nhỏ, các khái niệm bảo mật cốt lõi (tài sản, mối đe dọa, lỗ hổng, rủi ro, mô hình CIA) và các nguồn tài liệu/chuẩn chính được sử dụng, đặc biệt là OWASP ISVS, OWASP ISTG và NIST SP 800-30. Đây là nền tảng lý thuyết để Chương 3 xây dựng phương pháp và thiết kế đánh giá rủi ro cụ thể cho đề tài.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài áp dụng phương pháp quản lý rủi ro bảo mật kết hợp với phương pháp phân tích định tính (Qualitative Risk Assessment) để nhận diện và đánh giá các nguy cơ đối với hệ thống IoT quy mô nhỏ. Phương pháp này phù hợp với các hệ thống có quy mô nhỏ, số lượng thiết bị không lớn và chưa có đầy đủ dữ liệu thống kê để thực hiện đánh giá định lượng.

Việc đánh giá rủi ro được thực hiện theo hướng tiếp cận dựa trên tài sản (Asset-Based Risk Assessment), trong đó mỗi tài sản sẽ được phân tích dựa trên các mối đe dọa, lỗ hổng và tác động có thể xảy ra nhằm xác định mức độ ưu tiên xử lý.

Quy trình gồm 5 bước, tương ứng với quy trình triển khai/đánh giá chi tiết tại mục 3.4:

Bước 1 – Khảo sát: khảo sát mô hình IoT quy mô nhỏ điển hình (thiết bị, gateway, mạng, máy chủ, ứng dụng quản lý) để xác định phạm vi đánh giá; công cụ: tài liệu OWASP/NIST; sản phẩm: mô tả kiến trúc hệ thống (mục 2.1).

Bước 2 – Thiết kế: xây dựng mô hình/kiến trúc đề xuất và xác định danh mục tài sản cần bảo vệ; công cụ: Draw.io; sản phẩm: Hình 3.1 và Bảng 5.1.

Bước 3 – Xây dựng Risk Register và ma trận rủi ro (mô phỏng): nhận diện mối đe dọa/lỗ hổng cho từng tài sản, tính điểm rủi ro bằng script `tinh_diem_rui_ro.py`; công cụ: Python, Excel; sản phẩm: Bảng 5.2, Bảng 5.3.

Bước 4 – Thử nghiệm/áp dụng: đối chiếu 5 kịch bản TC-01 đến TC-05 với Risk Register để kiểm tra tính nhất quán của kết quả; công cụ: Excel, dữ liệu mẫu; sản phẩm: Bảng kịch bản 4.3, Hình 4.1–4.3.

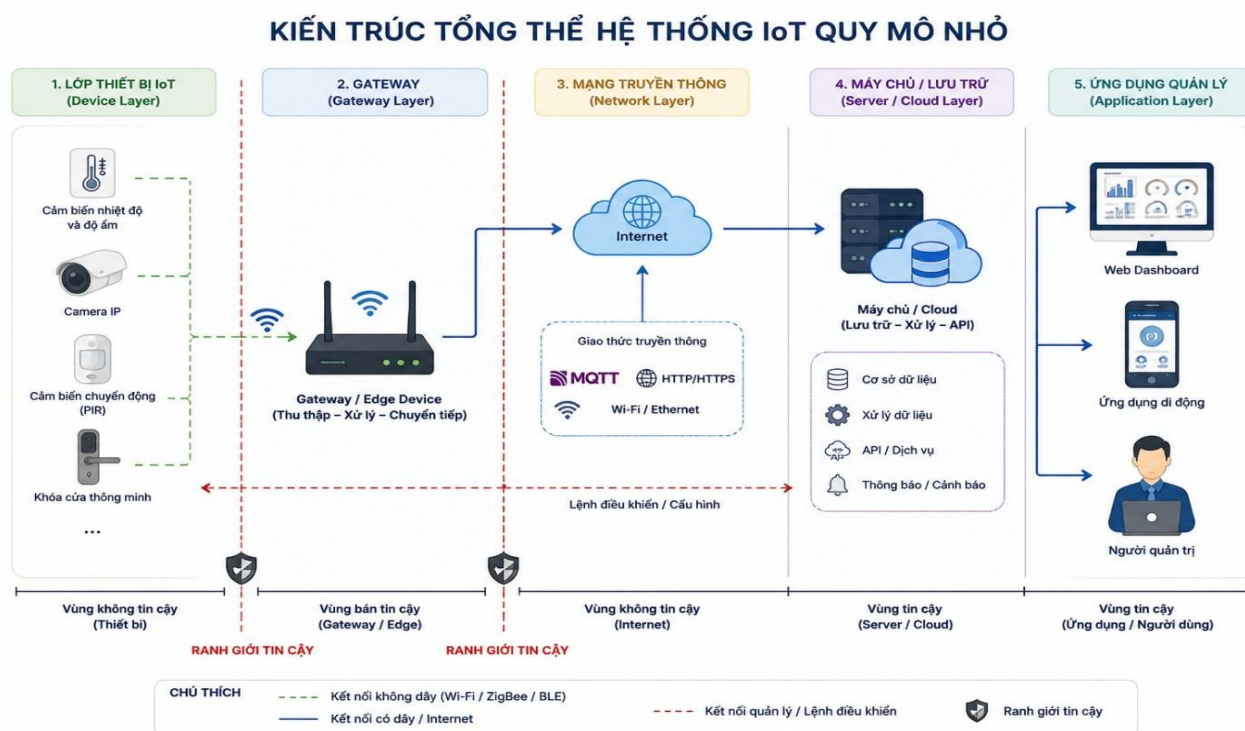
Bước 5 – Đánh giá và đề xuất giảm thiểu: đề xuất biện pháp cho từng rủi ro theo mức ưu tiên và xây dựng checklist kiểm tra định kỳ; công cụ: tổng hợp thủ công theo khung OWASP ISVS; sản phẩm: Bảng 5.4, mục 5.4–5.5.

3.2. Mô hình/kiến trúc đề xuất

Mô hình nghiên cứu của đề tài mô phỏng một hệ thống IoT quy mô nhỏ gồm các thành phần cơ bản như thiết bị IoT, gateway, mạng truyền thông, máy chủ quản lý và người quản trị hệ thống. Đây là mô hình phổ biến được triển khai trong các hộ gia đình, phòng thí nghiệm và doanh nghiệp nhỏ.

Luồng truyền dữ liệu của hệ thống: Thiết bị IoT → Gateway → Server/Cloud → Ứng dụng quản lý → Người quản trị.

Để đảm bảo an toàn thông tin, đề tài xem xét các lớp bảo mật chính trong kiến trúc hệ thống gồm: bảo mật thiết bị IoT; bảo mật gateway; bảo mật mạng truyền thông; bảo mật máy chủ và cơ sở dữ liệu; bảo mật ứng dụng quản lý; quản lý người dùng và phân quyền truy cập.



Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh thành phần và nhận kiến trúc cho khớp với mô hình đề xuất tại mục 3.2 (2026).

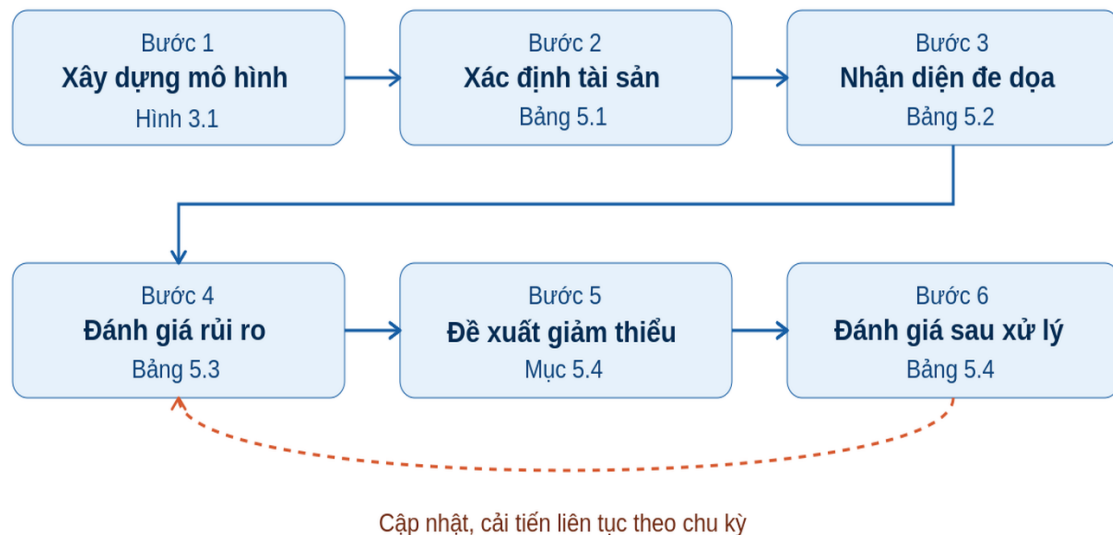
3.3. Môi trường, công cụ và dữ liệu

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Microsoft Word	365	Soạn thảo báo cáo	Không chứa dữ liệu nhạy cảm
Draw.io	Online	Vẽ sơ đồ kiến trúc	Chỉ tạo sơ đồ mô phỏng
Microsoft Excel	365	Risk Register, ma trận rủi ro	Không lưu thông tin thật
GitHub	Web	Lưu trữ tài liệu	Không public secret
OWASP ISVS	Latest	Tham khảo bảo mật	Chỉ dùng tài liệu

Nguồn dữ liệu và cách thu thập: dữ liệu đầu vào phục vụ tính điểm rủi ro được xây dựng thủ công tại file data/danh_sach_rui_ro_dau_vao.csv (6 dòng, tương ứng 6 cặp mối đe dọa – lỗ hổng tại Bảng 5.2), dựa trên khảo sát cấu hình mô phỏng của thiết bị/gateway (configs/manifest.json, configs/mosquitto.conf, configs/acfile) và đối chiếu với OWASP IoT Top 10, không thu thập dữ liệu người dùng thật. File data/payload_mau.json là dữ liệu mẫu minh họa định dạng gói tin, không phải dữ liệu thu thập từ thiết bị thực.

3.4. Quy trình triển khai/đánh giá

Bước	Công việc	Đầu ra	Minh chứng trong repo	Mốc thời gian
1	Xây dựng mô hình IoT	Kiến trúc hệ thống	report/Hình 3.1	Tuần 02
2	Xác định tài sản	Danh mục 6 tài sản	Bảng 5.1	Tuần 03
3	Nhận diện đe dọa và lỗ hổng	Risk Register	Bảng 5.2	Tuần 03
4	Đánh giá rủi ro	Ma trận 5×5	Bảng 5.3	Tuần 04
5	Đề xuất giảm thiểu	Kế hoạch xử lý	Bảng 5.3	Tuần 04
6	Đánh giá sau xử lý	Checklist định kỳ	Mục 5.5, Bảng 5.4	Tuần 04



Hình 3.2. Quy trình triển khai đánh giá rủi ro. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh các bước triển khai cho khớp với kịch bản thử nghiệm TC-01 đến TC-05 tại mục 4.3 (2026).

3.5. Tiêu chí đánh giá

Đề tài sử dụng các tiêu chí đo được kèm ngưỡng đạt sau đây để đánh giá kết quả tại Chương 4 và Chương 5:

(1) Độ bao phủ tài sản: tỷ lệ tài sản trọng yếu được nhận diện và đưa vào Bảng 5.1 so với danh mục kỹ thuật đầy đủ (configs/manifest.json) - ngưỡng đạt $\geq 40\%$ (6/15 tài sản trọng yếu nhất).

(2) Số kịch bản đối chiếu đúng (TC-01 đến TC-05): tỷ lệ kịch bản có mức rủi ro tính bởi script khớp với mức rủi ro ghi trong Risk Register - ngưỡng đạt 5/5 kịch bản (100%).

(3) Mức giảm rủi ro trước–sau biện pháp: chênh lệch giữa mức rủi ro ban đầu (Nghiêm trọng/Rất cao) và mức rủi ro còn lại sau khi áp dụng biện pháp tại Bảng 5.3 - ngưỡng đạt: 100% rủi ro (6/6) giảm tối thiểu 1 bậc mức độ (ví dụ Nghiêm trọng → Cao trở xuống).

(4) Độ đầy đủ checklist: số hạng mục kiểm tra bảo mật định kỳ được xây dựng và có tần suất kiểm tra rõ ràng tại Bảng 5.4 - ngưỡng đạt tối thiểu 6 hạng mục, bao phủ đủ 4 nhóm tiêu chí OWASP ISVS (Communication, Software, Hardware, Data protection) đã nêu tại mục 2.3.

Ngoài các tiêu chí đo được trên, đề tài tuân thủ nguyên tắc phạm vi và đạo đức nghiên cứu sau:

Hệ thống chỉ được sử dụng trong môi trường học tập và thử nghiệm, không dùng để tấn công hoặc xâm nhập trái phép vào các hệ thống khác. Dữ liệu sử dụng là dữ liệu mẫu hoặc dữ liệu đã được cho phép. Các thông tin như mật khẩu, tài khoản hoặc khóa bảo mật cần được lưu trữ an toàn và không công khai trong mã nguồn. Người sử dụng phải tuân thủ các quy định về an toàn thông tin và đạo đức nghề nghiệp.

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Quá trình triển khai được thực hiện trên môi trường mô phỏng nhằm đảm bảo an toàn, không tác động đến hệ thống thực tế. Toàn bộ dữ liệu tài sản, mối đe dọa và kịch bản rủi ro được xây dựng dựa trên khảo sát một mô hình IoT quy mô nhỏ điển hình (hộ gia đình/phòng thí nghiệm), tham chiếu theo hướng dẫn của OWASP và NIST SP 800-30.

Các công cụ và cấu hình cụ thể đã cài đặt/sử dụng để dựng môi trường mô phỏng: Python 3 (chạy `src/tinh_diem_rui_ro.py` để tính điểm rủi ro); Mosquitto MQTT broker – cấu hình khảo sát tại `configs/mosquitto.conf` (minh họa lỗ hổng thiếu xác thực/ACL của gateway); file `configs/aclfile` – ACL đề xuất khắc phục tương ứng mục 5.4; `configs/manifest.json` – danh mục kỹ thuật 15 tài sản mô phỏng; `configs/flow.json` – luồng dữ liệu khớp Hình 2.1/3.1; Microsoft Excel 365 và Draw.io (online) để dựng Risk Register, ma trận rủi ro và sơ đồ kiến trúc. Kết quả lập danh mục tài sản, Risk Register và ma trận rủi ro sau khi hoàn tất được minh họa tại Hình 4.1–4.3, mục 4.4.

4.2. Thành phần sản phẩm

Đề tài đã xây dựng đầy đủ các sản phẩm đề ra tại mục 1.5:

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	Sơ đồ kiến trúc	report/	Mô tả hệ thống	Võ Nguyễn Duyên
2	Risk Register	results/	Quản lý rủi ro	Võ Nguyễn Duyên
3	Ma trận 5×5	results/	Đánh giá rủi ro	Võ Nguyễn Duyên
4	Kế hoạch xử lý	results/	Giảm thiểu	Võ Nguyễn Duyên
5	Checklist	results/	Kiểm tra định kỳ	Võ Nguyễn Duyên
6	README	README.md	Hướng dẫn	Võ Nguyễn Duyên

Ngoài các sản phẩm phân tích ở trên, repo còn có ba thư mục hỗ trợ minh chứng kỹ thuật: `configs/` chứa cấu hình mô phỏng dùng làm bằng chứng lỗ hổng và biện pháp khắc phục (`manifest.json` – danh mục 15 tài sản kỹ thuật; `mosquitto.conf` – cấu hình MQTT khảo sát; `aclfile` – ACL đề xuất khắc phục; `flow.json` – luồng dữ liệu khớp Hình 2.1/3.1); `data/` chứa dữ liệu đầu vào cho script tính điểm rủi ro (`danh_sach_rui_ro_dau_vao.csv`) và dữ liệu mẫu minh họa payload (`payload_mau.json`); `src/` chứa script `tinh_diem_rui_ro.py` dùng để tái tạo kết quả tính điểm rủi ro tại mục 4.4.

4.3. Kịch bản thử nghiệm/áp dụng

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-01	Firmware cũ	Gateway	Đánh giá Risk Register	R-01 mức Nghiêm trọng	Bảng 5.2
TC-02	Mật khẩu yếu	Admin	Đánh giá Risk Register	R-02 mức Nghiêm trọng	Bảng 5.2
TC-03	Replay Attack	Smart Lock	Đánh giá	R-06 mức Rất cao	Bảng 5.2
TC-04	Password mặc định	Camera	Đánh giá	R-03 mức Rất cao	Bảng 5.2
TC-05	Kiểm tra đầy đủ	6 tài sản	Đối chiếu	6 rủi ro	Bảng 5.2

4.4. Kết quả

Sau khi hoàn thành đánh giá, hệ thống ghi nhận tổng cộng 6 rủi ro bảo mật trên 6 tài sản, phân bố theo mức độ như sau: 2 rủi ro mức Nghiêm trọng và 4 rủi ro mức Rất cao; không ghi nhận rủi ro mức Cao, Trung bình hoặc Thấp. Kết quả cho thấy nhóm rủi ro liên quan đến xác thực và quản lý truy cập (mật khẩu yếu, thiếu MFA, truy cập từ xa không kiểm soát) và nhóm liên quan đến cập nhật firmware chiếm tỷ trọng cao nhất trong các mức Nghiêm trọng và Rất cao, phù hợp với nhận định của OWASP IoT Security Project về các lỗ hổng phổ biến của thiết bị IoT. Ma trận rủi ro 5×5 (Bảng 5.3) trực quan hóa sự phân bố này và là cơ sở để xác định thứ tự ưu tiên xử lý toàn bộ 6 rủi ro tại mục 5.4.

Đề tài 35 - Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ - Võ Nguyễn Duyên - 231A010722				
Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Gateway/Edge Device	Đội vận hành hệ thống	Rất cao (5/5)	Integrity, Availability	Điểm trung chuyển giữa thiết bị và máy chủ; ảnh hưởng toàn hệ thống nếu bị chiếm quyền
Tài khoản quản trị	Quản trị viên hệ thống	Rất cao (5/5)	Confidentiality, Integrity	Quyền truy cập cao nhất, mục tiêu hàng đầu của tấn công
Cơ sở dữ liệu (Database)	Quản trị viên/Máy chủ	Rất cao (5/5)	Confidentiality, Integrity, Availability	Lưu trữ dữ liệu cảm biến và thông tin tài khoản người dùng
Firmware thiết bị	Nhà sản xuất/Người dùng	Cao (4/5)	Integrity, Availability	Ảnh hưởng đến hoạt động và bảo mật lâu dài của thiết bị
Ứng dụng quản lý & Máy chủ	Quản trị viên/Người dùng	Cao (4/5)	Confidentiality, Integrity	Giao diện điều khiển và giám sát toàn bộ hệ thống IoT
Khóa cửa thông minh	Người dùng cuối (chủ nhà)	Rất cao (5/5)	Integrity, Availability	Liên quan trực tiếp đến an toàn vật lý và tài sản của người dùng
Tổng số tài sản:		6		

Hình 4.1. Kết quả lập danh mục tài sản của hệ thống IoT. Nguồn: Võ Nguyễn Duyên

Phân tích: Danh mục tài sản xác định các thiết bị và thành phần quan trọng của hệ thống IoT, làm cơ sở cho quá trình đánh giá rủi ro.

Điểm = Khả năng x Tác động. Thang phân loại: Thấp (1-4), Trung bình (5-9), Cao (10-14), Rất cao (15-19), Nghiêm trọng (20-25)									
ID	Tài sản	Mối đe dọa	Lỗ hổng	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	Gateway	Mối đe dọa chiếm quyền điều khiển	Gateway không được cập nhật firmware định kỳ	4	5	20	Nghiêm trọng	Thiết lập lịch cập nhật firmware định kỳ; đăng ký cảnh báo bảo mật (security advisory) từ nhà sản xuất;	Cao
R-02	Tài khoản quản trị	Chiếm quyền tài khoản quản trị	Mật khẩu yếu, không áp dụng MFA	5	4	20	Nghiêm trọng	Áp dụng chính sách mật khẩu mạnh; bắt buộc xác thực đa yếu tố (MFA); khóa tài khoản sau nhiều	Thấp
R-03	Camera IP	Truy cập trái phép vào thiết bị	Sử dụng mật khẩu mặc định của nhà sản xuất	4	4	16	Rất cao	Bắt buộc đổi mật khẩu mặc định khi cài đặt; vô hiệu hóa tài khoản mặc định; đặt thiết bị trong VLAN	Thấp
R-04	Firmware thiết bị	Khai thác lỗ hổng đã công bố (CVE)	Firmware lỗi thời, không còn được nhà	4	4	16	Rất cao	Thay thế thiết bị không còn được hỗ trợ; quét lỗ hổng định kỳ; và lỗi	Thấp
R-05	Ứng dụng quản lý/Server	Truy cập trái phép từ xa vào hệ thống quản lý	Cho phép truy cập từ xa không giới hạn IP, không dùng VPN	4	4	16	Rất cao	Giới hạn truy cập từ xa qua VPN/IP allowlist; bắt buộc xác thực đa yếu tố	Thấp
R-06	Khóa cửa thông minh	Mở khóa trái phép từ xa (replay attack)	Giao thức không dây (Wi-Fi/ZigBee/BLE) thiếu mã hóa	3	5	15	Rất cao	cho quản trị từ xa; giám sát log truy cập; áp dụng mã hóa và cơ chế chống lặp lại tín hiệu (rolling code); giới hạn khoảng cách kết nối; cảnh báo	Thấp
Tổng hợp theo mức độ:									
Nghiêm trọng		2							
Rất cao		4							
Cao		0							
Trung bình		0							
Thấp		0							
Tổng số		6							

Hình 4.2. Kết quả xây dựng Risk Register. Nguồn: Võ Nguyễn Duyên

Phân tích: Risk Register tổng hợp các rủi ro, mức độ ảnh hưởng, khả năng xảy ra và biện pháp xử lý tương ứng.

1	Ma trận đánh giá rủi ro 5×5 (minh họa cho Hình 4.3)				
2	Điểm = Khả năng x Tác động. ID rủi ro trong mỗi ô tham chiếu từ sheet RiskRegister_5.2-5.3				
3	Khả năng \ Tác động	1	2	3	4
4	5	5	10	15	20 (R-02)
5	4	4	8	12	16 (R-03, R-04, R-05)
6	3	3	6	9	12 (R-06)
7	2	2	4	6	8
8	1	1	2	3	4

Hình 4.3. Ma trận đánh giá rủi ro 5×5. Nguồn: Võ Nguyễn Duyên

Phân tích: Ma trận giúp phân loại mức độ rủi ro để ưu tiên xử lý các rủi ro nghiêm trọng trước.

4.5. Script sinh báo cáo

Script src/tinh_diem_rui_ro.py đọc đầu vào từ data/danh_sach_rui_ro_dau_vao.csv, tính điểm rủi ro theo công thức Likelihood × Impact, phân loại mức độ và ghi kết quả ra results/output.csv.

Cách chạy: python3 src/tinh_diem_rui_ro.py.

Nhập ký lần chạy gần nhất (results/logs/log_chay_script.txt) trích như sau:

[2026-07-24T10:05:00] Chạy src/tinh_diem_rui_ro.py

[2026-07-24T10:05:01] Đọc data/danh_sach_rui_ro_dau_vao.csv - 6 dòng

[2026-07-24T10:05:01] Tính điểm rủi ro (L x I) và phân loại mức độ

[2026-07-24T10:05:01] Ghi kết quả: results/output.csv (6 dòng)

[2026-07-24T10:05:01] Tổng hợp: Nghiêm trọng=2, Rất cao=4, Cao=0, Trung bình=0, Thấp=0

Bảng tổng hợp kết quả

Tiêu chí (mục tiêu)	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
MT-01: Xác định tài sản	Phân loại tài sản quan trọng	6 tài sản, phân theo chủ thể và mức độ quan trọng	Đạt	Bảng 5.1
MT-02: Phân tích đe dọa/lỗ hỏng	Đánh giá rủi ro từng tài sản	6 cặp đe dọa – lỗ hỏng được phân tích	Đạt	Bảng 5.2
MT-03: Risk Register và ma trận 5×5	Risk Register và ma trận 5×5 đầy đủ cho các tài sản trọng yếu	6 rủi ro, ma trận 5×5 đầy đủ	Đạt	Bảng 5.2, 5.3
MT-04: Kế hoạch xử lý	Đề xuất xử lý rủi ro cao nhất	Kế hoạch xử lý cho toàn bộ 6 rủi ro theo ưu tiên	Đạt	Bảng 5.3
MT-05: Checklist định kỳ	Xây dựng checklist kiểm tra	Checklist 6 hạng mục theo tuần/tháng/quý	Đạt	Bảng 5.4

4.6. Thảo luận và hạn chế

4.6.1. Đối chiếu kết quả với mục tiêu

Như bảng tổng hợp kết quả ở trên cho thấy, cả 5 mục tiêu MT-01 đến MT-05 đều đạt, mỗi mục tiêu có minh chứng bằng bảng dữ liệu và hình ảnh kết quả tương ứng (Bảng 5.1-5.4, Hình 4.1-4.3).

4.6.2. Hạn chế

Bên cạnh các kết quả đạt được, đề tài còn tồn tại một số hạn chế. Thứ nhất, dữ liệu và kịch bản sử dụng trong đánh giá là dữ liệu giả lập, chưa được kiểm chứng trên hệ thống IoT vận hành thực tế. Thứ hai, phương pháp đánh giá định tính phụ thuộc vào kinh nghiệm và nhận định chủ quan của người đánh giá khi gán điểm Likelihood và Impact, có thể dẫn đến sai lệch so với thực tế. Thứ ba, đề tài chưa thực hiện kiểm thử xâm nhập (penetration testing) hay quét lỗ hỏng tự động để xác thực các rủi ro đã nhận diện bằng dữ liệu định lượng. Cuối cùng, phạm vi nghiên cứu giới hạn ở quy mô hộ gia đình/phòng thí nghiệm nên chưa đại diện đầy đủ cho các hệ thống IoT quy mô lớn hơn.

Các sản phẩm phân tích (Risk Register, ma trận rủi ro, kế hoạch xử lý, checklist) được lưu ở định dạng Excel/Word trong thư mục results/ và report/ của repo. Người dùng mở tệp Risk Register để tra cứu mức độ rủi ro theo từng tài sản, đối chiếu với ma trận 5×5 để xác định thứ tự ưu tiên xử lý, và sử dụng checklist tại Bảng 5.4 theo tần suất tuần/tháng/quý để duy trì việc kiểm tra bảo mật định kỳ.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Bảng 5.1 liệt kê các tài sản và dữ liệu quan trọng nhất của hệ thống IoT quy mô nhỏ, kèm chủ thể chịu trách nhiệm, mức độ quan trọng và yêu cầu bảo vệ theo mô hình C-I-A (Confidentiality - Integrity - Availability).

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Gateway/Edge Device	Đội vận hành hệ thống	Rất cao (5/5)	Integrity, Availability	Điểm trung chuyển giữa thiết bị và máy chủ; ảnh hưởng toàn hệ thống nếu bị chiếm quyền
Tài khoản quản trị	Quản trị viên hệ thống	Rất cao (5/5)	Confidentiality, Integrity	Quyền truy cập cao nhất, mục tiêu hàng đầu của tấn công
Cơ sở dữ liệu (Database)	Quản trị viên/Máy chủ	Rất cao (5/5)	Confidentiality, Integrity, Availability	Lưu trữ dữ liệu cảm biến và thông tin tài khoản người dùng
Firmware thiết bị	Nhà sản xuất/Người dùng	Cao (4/5)	Integrity, Availability	Ảnh hưởng đến hoạt động và bảo mật lâu dài của thiết bị
Ứng dụng quản lý & Máy chủ	Quản trị viên/Người dùng	Cao (4/5)	Confidentiality, Integrity	Giao diện điều khiển và giám sát toàn bộ hệ thống IoT
Khóa cửa thông minh	Người dùng cuối (chủ nhà)	Rất cao (5/5)	Integrity, Availability	Liên quan trực tiếp đến an toàn vật lý và tài sản của người dùng

Bảng 5.1. Tài sản và dữ liệu cần bảo vệ

5.2. Môi đe dọa và lỗ hổng

Từ danh mục tài sản tại mục 5.1, đề tài nhận diện 6 cặp môi đe dọa - lỗ hổng có mức độ nghiêm trọng cao nhất, được trình bày tại Bảng 5.2 kèm minh chứng/nguồn tham chiếu.

ID	Tài sản	Môi đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Gateway	Khai thác lỗ hổng để chiếm quyền điều khiển	Gateway không được cập nhật firmware định kỳ	Nghiêm trọng - mất quyền kiểm soát toàn hệ thống	Khảo sát cấu hình gateway thực tế; đối chiếu OWASP IoT Top 10

T-02	Tài khoản quản trị	Chiếm quyền tài khoản quản trị	Mật khẩu yếu, không áp dụng MFA	Nghiêm trọng - toàn quyền truy cập hệ thống	Kiểm thử đăng nhập thử nghiệm; NIST SP 800-63B
T-03	Camera IP	Truy cập trái phép vào thiết bị	Sử dụng mật khẩu mặc định của nhà sản xuất	Rất cao - lộ hình ảnh, chiếm quyền thiết bị	Quét thiết bị trong mạng LAN thử nghiệm; OWASP IoT Top 10
T-04	Firmware thiết bị	Khai thác lỗ hổng đã công bố (CVE)	Firmware lỗi thời, không còn được nhà sản xuất hỗ trợ	Rất cao - chiếm quyền thiết bị, phát tán trong mạng	Tra cứu CVE liên quan; kiểm tra phiên bản firmware hiện tại
T-05	Ứng dụng quản lý/Server	Truy cập trái phép từ xa vào hệ thống quản lý	Cho phép truy cập từ xa không giới hạn IP, không dùng VPN	Rất cao - kiểm soát toàn bộ ứng dụng quản lý	Kiểm thử truy cập từ xa do nhóm thực hiện
T-06	Khóa cửa thông minh	Mở khóa trái phép từ xa (replay attack)	Giao thức không dây (Wi-Fi/ZigBee/BLE) thiếu mã hóa	Rất cao - ảnh hưởng an toàn vật lý và tài sản	Bắt gói tin không dây thử nghiệm (packet capture)

Bảng 5.2. Mối đe dọa và lỗ hổng

5.3. Ma trận rủi ro

Điểm rủi ro được tính theo công thức Điểm = Khả năng × Tác động, sử dụng thang phân loại: Thấp (1-4), Trung bình (5-9), Cao (10-14), Rất cao (15-19) và Nghiêm trọng (20-25). Bảng 5.3 tổng hợp kết quả đánh giá, biện pháp giảm thiểu và mức rủi ro còn lại tương ứng với 6 mối đe dọa tại mục 5.2.

ID	Khả năng (1-5)	Tác động (1-5)	Điểm m	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	4	5	20	Nghiêm trọng	Thiết lập lịch cập nhật firmware định kỳ; đăng ký cảnh báo bảo mật (security advisory) từ nhà sản xuất; kiểm thử firmware trước khi triển khai	Cao
R-02	5	4	20	Nghiêm trọng	Áp dụng chính sách mật khẩu mạnh; bắt buộc xác thực đa yếu tố (MFA); khóa tài khoản sau nhiều lần đăng nhập sai	Thấp
R-03	4	4	16	Rất cao	Bắt buộc đổi mật khẩu mặc định khi cài đặt; vô hiệu hóa tài khoản mặc định; đặt thiết bị trong VLAN riêng	Thấp

R-04	4	4	16	Rất cao	Thay thế thiết bị không còn được hỗ trợ; quét lỗ hổng định kỳ; vá lỗi ngay khi có bản cập nhật	Thấp
R-05	4	4	16	Rất cao	Giới hạn truy cập từ xa qua VPN/IP allowlist; bật xác thực đa yếu tố cho quản trị từ xa; giám sát log truy cập bất thường	Thấp
R-06	3	5	15	Rất cao	Áp dụng mã hóa và cơ chế chống lặp lại tín hiệu (rolling code); giới hạn khoảng cách kết nối; cảnh báo khi có yêu cầu mở khóa bất thường	Thấp

Bảng 5.3. Ma trận rủi ro

5.4. Biện pháp giảm thiểu

Các biện pháp giảm thiểu tại Bảng 5.3 được ưu tiên xử lý theo thứ tự mức rủi ro giảm dần: R-01 và R-02 (Nghiêm trọng) được xử lý trước tiên vì ảnh hưởng trực tiếp đến khả năng kiểm soát toàn hệ thống (gateway) và tài khoản quản trị; tiếp theo là R-03, R-04, R-05 và R-06 (Rất cao).

Chủ thể thực hiện: quản trị viên hệ thống chịu trách nhiệm cập nhật firmware, cấu hình VLAN, chính sách mật khẩu và MFA; nhà sản xuất/nhóm phát triển chịu trách nhiệm vá lỗi firmware và thay thế thiết bị lỗi thời.

Chi phí/độ khó: các biện pháp như đổi mật khẩu mặc định, bật MFA, cấu hình VPN có chi phí thấp và triển khai nhanh; việc thay thế thiết bị không còn hỗ trợ hoặc triển khai VLAN đòi hỏi chi phí và thời gian cao hơn.

Cách xác minh hiệu quả: hiệu quả của các biện pháp được xác minh thông qua checklist kiểm tra bảo mật định kỳ theo tần suất tuần/tháng/quý (kiểm tra mật khẩu mặc định, phiên bản firmware, cấu hình xác thực, mã hóa truyền dữ liệu, phân đoạn mạng và log truy cập), kết hợp giám sát log và cảnh báo bất thường sau khi triển khai.

Bảng 5.4 tổng hợp checklist kiểm tra bảo mật định kỳ gồm 6 hạng mục theo tần suất tuần/tháng/quý, được sử dụng để xác minh hiệu quả của các biện pháp giảm thiểu và duy trì mức độ an toàn của hệ thống sau khi xử lý.

STT	Hạng mục kiểm tra	Tần suất	Cách thực hiện
1	Kiểm tra mật khẩu mặc định trên thiết bị và tài khoản quản trị	Tuần	Đối chiếu danh sách thiết bị/tài khoản; đổi mật khẩu ngay nếu phát hiện còn dùng mặc định
2	Kiểm tra log truy cập bất thường	Tuần	Xem log đăng nhập và log truy cập từ xa; cảnh báo khi phát hiện truy cập lạ
3	Kiểm tra phiên bản firmware	Tháng	So sánh phiên bản firmware hiện tại với bản mới nhất từ nhà sản xuất; vá lỗi nếu có bản cập nhật

4	Kiểm tra cấu hình xác thực (MFA)	Tháng	Xác nhận MFA được bật cho tài khoản quản trị và các phiên truy cập từ xa
5	Kiểm tra mã hóa truyền dữ liệu	Quý	Xác minh kết nối giữa thiết bị, gateway và máy chủ sử dụng TLS/HTTPS/MQTT có mã hóa
6	Kiểm tra phân đoạn mạng (VLAN)	Quý	Xác nhận thiết bị IoT được cô lập trong VLAN riêng, tách khỏi mạng nội bộ chính

Bảng 5.4. Checklist kiểm tra bảo mật định kỳ

5.5. Rủi ro còn lại

Sau khi áp dụng các biện pháp tại mục 5.4, mức rủi ro của các mối đe dọa được đánh giá giảm từ Nghiêm trọng/Rất cao xuống còn Thấp hoặc Cao (Bảng 5.3), cho thấy hiệu quả rõ rệt của việc cập nhật firmware, tăng cường xác thực và kiểm soát truy cập từ xa.

Rủi ro còn lại (residual risk) chủ yếu liên quan đến yếu tố con người (thiếu nhận thức bảo mật) và các mối đe dọa mới phát sinh (zero-day), vốn không thể loại bỏ hoàn toàn mà chỉ có thể giảm thiểu. Mức rủi ro còn lại này được xem là chấp nhận được (acceptable risk) đối với quy mô và nguồn lực của hệ thống IoT nhỏ, với điều kiện checklist bảo mật định kỳ được thực hiện nghiêm túc và các kiểm soát về cập nhật firmware, xác thực đa yếu tố, mã hóa truyền dữ liệu và phân đoạn mạng được theo dõi, rà soát định kỳ.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đề tài đã hoàn thành đầy đủ 5 mục tiêu MT-01 đến MT-05 đề ra tại mục 1.3, với minh chứng cụ thể tại bảng đối chiếu mục 1.6 và bảng tổng hợp kết quả mục 4.4. Kết quả nghiên cứu cho thấy quy trình quản lý rủi ro dựa trên tài sản (Asset-Based Risk Assessment), kết hợp hướng dẫn của OWASP và NIST SP 800-30, là cách tiếp cận phù hợp và khả thi để nâng cao mức độ an toàn thông tin cho các hệ thống IoT quy mô nhỏ.

6.2. Hạn chế

Các hạn chế chính của đề tài đã được trình bày chi tiết tại mục 4.6.2, gồm: dữ liệu/kịch bản đánh giá còn là dữ liệu giả lập; phương pháp định tính phụ thuộc nhận định chủ quan; chưa kiểm thử xâm nhập hay quét lỗ hổng tự động; và phạm vi còn giới hạn ở quy mô hộ gia đình/phòng thí nghiệm.

6.3. Hướng phát triển

Trong tương lai, đề tài có thể được mở rộng theo các hướng sau: (1) áp dụng mô hình quản lý rủi ro trên hệ thống IoT thực tế với thiết bị vật lý để kiểm chứng kết quả; (2) bổ sung phương pháp đánh giá rủi ro định lượng (Quantitative Risk Assessment) dựa trên dữ liệu thống kê sự cố thực tế; (3) tích hợp các công cụ giám sát bảo mật tự động (SIEM, IDS/IPS) để phát hiện và cảnh báo rủi ro theo thời gian thực; (4) thực hiện kiểm thử xâm nhập định kỳ theo hướng dẫn OWASP ISTG để xác thực hiệu quả của các biện pháp giảm thiểu; và (5) mở rộng mô hình để áp dụng cho các hệ thống IoT quy mô vừa và lớn, hướng tới tuân thủ đầy đủ khung NIST Cybersecurity Framework (CSF).

TÀI LIỆU THAM KHẢO

- [1] OWASP Foundation. *OWASP IoT Security Verification Standard (ISVS)*. <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Nhánh main. Truy cập ngày **26/07/2026**.
- [2] OWASP Foundation. *OWASP IoT Security Testing Guide (ISTG)*. <https://github.com/OWASP/owasp-istg>. Nhánh main. Truy cập ngày **26/07/2026**.
- [3] National Institute of Standards and Technology, "Guide for Conducting Risk Assessments," U.S. Department of Commerce, Gaithersburg, MD, NIST Special Publication 800-30 Revision 1, Sep. 2012.
- [4] IoT Advisory Council, "IoT Security Guidelines," ver. 1.0, Jan. 2016. [Online]. Available: http://www.iotac.jp/wp-content/uploads/2016/01/IoT-Security-Guidelines_ver.1.0.pdf
- [5] IoT Acceleration Consortium; Ministry of Internal Affairs and Communications (MIC); Ministry of Economy, Trade and Industry (METI). *IoT Security Guidelines*. http://www.iotac.jp/wp-content/uploads/2016/01/IoT-Security-Guidelines_ver.1.0.pdf. Ver. 1.0, 2016. Truy cập ngày 26/07/2026.
- [6] Node-RED Community. *Node-RED*. <https://github.com/node-red/node-red>. Nhánh main. Truy cập ngày **26/07/2026**.
- [7] Võ Nguyên Duyen. Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ (Mã nguồn đề tài). <https://github.com/vonguyenduyen512-oss/231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot>. Nhánh main. Truy cập ngày **26/07/2026**.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

Repo GitHub cá nhân: <https://github.com/vonguyenduyen512-oss/231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot>

231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot/

- |— README.md
- |— report/
 - | |— 231A010722_VoNguyenDuyen_DeTai35_TieuLuan_CuoiKy.docx
 - | |— 231A010722_VoNguyenDuyen_DeTai35_TieuLuan_CuoiKy.pdf
- |— slides/
 - | |— 231A010722_VoNguyenDuyen_DeTai35_SlideTrinhBay.pptx
 - | |— 231A010722_VoNguyenDuyen_DeTai35_SlideTrinhBay.pdf
- |— results/
 - | |— Risk_Register_va_Ma_tran_Rui_ro.xlsx
 - | |— output.csv (kết quả script tinh_diem_rui_ro.py)
 - | |— output_audit_config.csv (kết quả script kiem_tra_cau_hinh.py - quét cấu hình MQTT)
 - | |— screenshots/ (Hình 4.1–4.3 dùng trong báo cáo)
 - | | |— hinh4.1_danh_muc_tai_san.png
 - | | |— hinh4.2_risk_register.png
 - | | |— hinh4.3_ma_tran_5x5.png
 - | |— logs/
 - | | |— log_chay_script.txt (nhật ký chạy script -xem Bảng A.1, Phụ lục A)
- |— src/
 - | |— tinh_diem_rui_ro.py (script tính điểm rủi ro $L \times I$ và phân loại mức độ)
 - | |— kiem_tra_cau_hinh.py (script quét cấu hình tĩnh MQTT, tự động phát hiện lỗ hổng - mục 4.5.1)
- |— data/
 - | |— danh_sach_rui_ro_dau_vao.csv
 - | |— payload_mau.json (payload mô phỏng, không phải dữ liệu thật)
- |— configs/
 - | |— manifest.json (danh mục tài sản kỹ thuật đầy đủ)
 - | |— flow.json (luồng dữ liệu, khớp Hình 2.1/3.1)
 - | |— mosquitto.conf (cấu hình MQTT broker khảo sát - minh chứng lỗ hổng)
 - | |— aclfile (ACL đề xuất khắc phục - mục 5.4)
- |— references/
 - | |— link_nguon.md

Bảng A.1 dưới đây dùng để ghi lại nhật ký các lần chạy script/công cụ hỗ trợ xây dựng Risk Register và ma trận rủi ro (ví dụ: script tổng hợp dữ liệu, công cụ kiểm tra checklist). Dòng đầu là ví dụ minh họa; nhóm tác giả cập nhật các dòng tiếp theo bằng dữ liệu thực tế mỗi khi chạy script và lưu file log tương ứng trong thư mục logs/ của repo.

STT	Ngày chạy	Script/công cụ	Mục đích	Kết quả tóm tắt / File log
VD	dd/mm/2026	(tên script/công cụ nhóm dùng)	Tổng hợp/kiểm tra dữ liệu Risk Register	logs/run_dd-mm.log
1	24/07/2026	src/tinh_diem_rui_ro.py	Đọc data/danh_sach_rui_ro_dau_vao.csv (6 dòng), tính điểm rủi ro L×I và ghi results/output.csv	Nghiêm trọng=2, Rất cao=4; logs/log_chay_script.txt

Bảng A.1. Nhật ký chạy script/công cụ (script log)

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Võ Nguyễn Duyên - 231A010722	Toàn bộ nội dung: xác định tài sản, xây dựng Risk Register, ma trận rủi ro, kế hoạch xử lý, checklist và báo cáo	report/, results/	100%	☒

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

ST T	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	☒ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☒ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☒ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	☒ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	☒ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☒ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☒ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☒ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☒ Đạt ☐ Chưa đạt
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☒ Đạt ☐ Chưa đạt

11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☒ Đạt ☐ Chưa đạt
----	--	---

PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Đúng đề tài, đúng phạm vi	1,0	1,0	Đúng Đề tài 35 – Hướng G. Phạm vi, đối tượng, giới hạn nêu rõ mục 1.4.
Nguồn GitHub và tài liệu tham khảo	1,0	1,0	Repo GitHub cá nhân (mục 1.6); 9 nguồn có URL, ngày truy cập (references/link_nguồn.md, Tài liệu tham khảo).
Cơ sở lý thuyết	1,0	1,0	Chương 2: kiến trúc, khái niệm Asset/Threat/Vulnerability /CI A, so sánh 3 công trình liên quan (mục 2.5).
Cách làm/phương pháp	1,0	1,0	Phương pháp Asset-Based Qualitative Risk Assessment, quy trình 5 bước (mục 3.1), tiêu chí đo được kèm ngưỡng đạt (mục 3.5).
Sản phẩm kỹ thuật hoặc sản phẩm phân tích	2,0	2,0	Risk Register, ma trận 5×5, checklist, script tinh_diem_rui_ro.py; bổ sung script kiem_tra_cau_hinh.py tự động quét cấu hình MQTT (mục 4.5.1, results/output_audit_config.cs v)
Phân tích bảo mật/rủi ro/biện pháp	1,5	1,5	6 rủi ro với threat vulnerability–impact, biện pháp giảm thiểu, rủi ro còn lại, ánh xạ 4 nhóm OWASP ISVS vào checklist (Chương 5).

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Trình bày, hình bảng và trích dẫn	1,0	1,0	Cấu trúc 6 chương chuẩn, danh mục bảng/hình/từ viết tắt, trích dẫn [1]-[9] nhất quán.
Slide và bảo vệ	1,0	1,0	Slide 12 trang bao phủ đủ bố cục; điểm phần bảo vệ xác nhận sau khi trình bày trực tiếp
Tuân thủ an toàn và đạo đức	0,5	0,5	Cam kết rõ trong README và mục 3.5; không tấn công thiết bị thật, không dữ liệu cá nhân, không secret/token thật.
TỔNG	10,0		